



Cybersecurity Maturity Dashboard — Aetheris Therapeutics S.p.A.

Quadro di Sintesi della Maturità GRC (NIST CSF v1.1 & ISO/IEC 27001:2022)

Standard di Riferimento: NIST CSF v1.1 & ISO/IEC 27001:2022

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: EXEC-DSH-2026-02

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Riservato al Board

Data di Efficacia: Agosto 2026

1. Executive Summary e Livello di Maturità Complessivo

L'attività di assessment condotta ad **Agosto 2026** ha assegnato ad **Aetheris Therapeutics S.p.A.** un livello di maturità complessivo di **1.74 / 5.0 (Tier 1 - Partial / Reactive)** secondo la scala di maturità CMMI/NIST.

L'organizzazione presenta buone basi infrastrutturali e di protezione fisica (Backup, Firewall, Badge), ma mostra significative lacune procedurali e di monitoraggio continuo nei domini di Governance, Risk Management e Incident Response.

2. NIST Cybersecurity Framework v1.1 — Valutazione per Domini

2.1 Tabella Sinottica per Funzione Core

Funzione NIST Core	Punteggio Attuale	Target Anno 1	Gap	Livello di Maturità Corrente
IDENTIFY (ID)	1.4 / 5.0	3.5 / 5.0	-2.1	Tier 1 — Gestione asset manuale, manca Registro GDPR
PROTECT (PR)	2.1 / 5.0	4.0 / 5.0	-1.9	Tier 2 — Cifratura attiva, ma assenza di MFA e PAM
DETECT (DE)	1.2 / 5.0	3.5 / 5.0	-2.3	Tier 1 — Assenza di SIEM, log non correlati h24
RESPOND (RS)	1.0 / 5.0	3.5 / 5.0	-2.5	Tier 1 — Nessun Incident Response Plan formalizzato
RECOVER (RC)	3.0 / 5.0	4.0 / 5.0	-1.0	Tier 3 — Backup immutabili su Azure e test di DR

2.2 Visualizzazione Grafica dello Stato dei Domini NIST

- Identify (1.4 / 5.0): 28%
- Protect (2.1 / 5.0): 42%
- Detect (1.2 / 5.0): 24%
- Respond (1.0 / 5.0): 20%
- Recover (3.0 / 5.0): 60%

3. ISO/IEC 27001:2022 Annex A — Stato di Conformità dei Controlli

I 93 controlli dell'Annex A di ISO 27001:2022 sono stati valutati e raggruppati nelle 4 macro-categorie tematiche stabilite dal nuovo aggiornamento dello standard:

Categoria Controlli ISO	Controlli Totali	Conformi (PASS)	Non Conformi (NC)	% Conformità Attuale
A.5 Controlli Organizzativi	37	1	36	2.7%
A.6 Controlli sul Personale	8	0	8	0.0%
A.7 Controlli Fisici	14	1	13	7.1%
A.8 Controlli Tecnologici	34	2	32	5.8%
TOTALE COMPLESSIVO	93	4	89	4.3%

4. Analisi dei Gap e Indicatori Chiave di Prestazione (KPI)

4.1 Gap Principali da Colmare

- Governance & Legal:** Assenza di politiche approvate dalla Direzione e mancanza della mappatura GDPR Art. 30 per la gestione dei dati clinici R&D.
- Identity & Access Management (IAM):** Autenticazione VPN senza MFA e presenza di utenze amministrative condivise prive di sistemi PAM.
- Security Operations & Monitoring:** Assenza di una piattaforma SIEM per la correlazione centralizzata dei log e totale mancanza di presidio SOC h24.
- Resilienza & Incident Response:** Mancanza di un piano formale di risposta agli incidenti (IRP) e assenza di esercitazioni periodiche.

4.2 KPI Target post-Remediation (Proiezione 12 Mesi)

Indicatore di Prestazione (KPI)	Stato Attuale	Target Anno 1	Strumento di Misura
Copertura MFA su Accessi Remoti	0%	100%	Audit log Azure AD / Conditional Access
Utenze Admin Condivise Attive	5	0	Active Directory Inventory / PAM Vault
Copertura Monitoraggio Log SIEM/SOC	0%	100%	Dashboard Microsoft Sentinel
Mean Time to Detect (MTTD)	Non misurabile	< 15 Minuti	SLA Servizio MSSP / SOC
Conformità Controlli ISO 27001 Annex A	4.3%	> 85%	Re-Audit SGSI Stage 1

5. Roadmap Sintetica di Maturazione (Phased Target)

Fase	Periodo Target	Focus Operativo Principale
Fase 1	Q3 2026	Remediation Critica: Enforce MFA su VPN, disattivazione admin condivisi, IRP base e Registro GDPR Art. 30.
Fase 2	Q4 2026	Strumentazione Tech: Deploy PAM Vault, attivazione SIEM Sentinel con SOC h24 e ITAM automatico.
Fase 3	Q1 2027	Governance & Awareness: Rollout Policy SGSI, campagne di phishing simulation e Security Annex fornitori.
Fase 4	Q2 2027	Audit & Certificazione: Internal Audit ISO 19011, Management Review e Audit di Certificazione Stage 1/2.

6. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026